SENTINEL

Full Application Audit

Bugs - detection integrity - data wiring - security - UI/UX - roadmap

July 19, 2026 - build v4.8.3

At a glance

2	Critical security issues
6	High-severity findings (detection + wiring + FE)
33	Total findings across the codebase
11	UI/UX enhancements proposed (2 shown before/after)

Findings marked "verified in code" were confirmed against the source; "plausible" ones are strong but not runtime-confirmed in this environment.

Executive summary

SENTINEL is a genuinely capable tool - the cross-referencing of time-clock, delivery, and GPS data is sound, and the recent Performance and reporting work is strong. This audit found no crashes or data-corruption bugs. The issues that matter cluster in four areas:

1. Security - fix today

Live B600 timeclock credentials (admin / admin12345) and an open LLM proxy on your Anthropic key are sitting in public, no-auth endpoints. A mutating GET can rewrite every score. These are not theoretical - they are one URL away.

2. The detector can hide theft in the "clean" bucket

Three separate paths (missing travel data, a missing/misspelled punch, and a single-vector cap) can file real theft as "clean" or cap it at "medium." A manager filtering by high/critical can miss the worst offenders. The dollar math is right; the risk category they act on is not.

3. Two screens disagree

Because the Performance tab only counts active-roster drivers while the headline counts everyone, a terminated offender shows in one number and vanishes from the other - with no explanation. Several smaller display bugs (a trend arrow that means the opposite thing on a printed coaching card, a "vs typical" column that changes meaning on sort, hardcoded values shown as live config) erode trust in the numbers.

4. UI polish and reach

The anomalies feed is an unbounded multi-thousand-row wall and the comparison table is unusable on a phone; both are quick, high-impact fixes shown before/after later in this report. A batch of accessibility gaps (pinch-zoom disabled, low-contrast text, unlabeled charts) is worth a pass.

None of the detection findings mean the app is "wrong" day to day - they are edge and boundary cases - but on a tool used to discipline people, edges matter. The security items should be treated as urgent.

1. Security (fix immediately)

CRITICAL **S1 - Hardcoded B600 timeclock credentials in a public endpoint**

`netlify/functions/totalpass-scraper.js:131-134`

verified in code

The scraper falls back to username 'admin', password 'admin12345', host 'b600.atlantafreightquotes.com' when env vars are unset. The function is public, no auth, wildcard CORS. Anyone with the site URL can pull the whole fleet's timecards or log directly into the clock. The credentials are also permanently in git history.

Fix: Remove the literals, fail closed when env is unset, rotate the B600 password now, and scrub git history.

CRITICAL **S2 - Open LLM proxy on the operator's Anthropic key**

`netlify/functions/sentinel-ai.js:23,92,94`

verified in code

The _rawPrompt request field is forwarded verbatim to Claude with max_tokens 3000 using the server ANTHROPIC_API_KEY. Public, no auth, and not even called by the current UI - pure attack surface for cost abuse and data exfiltration.

Fix: Delete the _rawPrompt branch, or gate the whole function.

HIGH **S3 - A GET request rewrites every stored score (bot-triggerable)**

`netlify/functions/sentinel-rescore-all.js`

verified in code

The default GET on this public URL kicks off a background job that rewrites stolenDollars / riskLevel / riskScore on all ~14,000 records. Any prefetcher, uptime monitor, or link-preview bot that fetches the URL starts a full rescore.

Fix: Require POST to kick off; keep GET status-only (the ?status=true path already exists).

HIGH **S4 - Multiple expensive / destructive endpoints are anonymously invokable**

`historical-backfill, compute-baselines, totalpass-scraper, sentinel-ai`

verified in code

No-auth is fine for reads, but these are writes / full rescans / scrapes with wildcard CORS, all firable anonymously. A single scripted loop could churn Firestore writes or the Google/Anthropic bills continuously.

Fix: Add a shared kickoff guard (POST + a lightweight shared token, or Netlify-level restriction) on every mutating endpoint.

MEDIUM **S5 - Old Firebase Web API key still in git history**

`git history (deleted background file)`

verified in code

Carried over from an earlier cleanup; the key is inert for reads under current rules but should not remain in history.

Fix: Rotate the key in the Google console.

---

2. Detection integrity (can mask or mis-band theft)

HIGH **D1 - One-vector theft can never exceed 'medium' risk**

`_sentinel-engine.js:94-101`

verified in code

A single scored component maxes at 40 (a 'critical' flag), but the bands need 45 for 'high' and 70 for 'critical'. So a driver who steals 3 hours every single morning (one critical flag = 40) is filed 'medium' forever. Any manager triaging by high/critical never sees the largest single-vector thieves. The dollar figure is correct - the category they filter and sort on is not.

Fix: Promote a lone critical component to high/critical, or lower the band cutoffs, or derive the band partly from stolen minutes - applied identically in engine, scan, and rescore.

HIGH D2 - Missing travel time silently scores the day 'clean' - and never heals

`_sentinel-engine.js:96-101,254; _distance.js:157-192; _sentinel-rescore.js:203-206`

verified in code

When the Google travel estimate is null (a transient API failure, an unroutable address cached for 30 days, or both sources absent), the leg becomes 'no_data', contributes zero, and a day with a real punch and deliveries lands at riskLevel 'clean'. Rescore reuses the stored null and never re-fetches, so the miss is permanent until a fresh day-scan. Real theft hides in the exact bucket managers trust as empty.

Fix: Treat punch+delivery+no-travel as a quarantine/retry state, not 'clean'; re-fetch travel on rescore or mark such records for re-scan.

HIGH D3 - No punch / name mismatch scores the whole day 'clean'

`_sentinel-scan.js:130-152; _sentinel-engine.js:227-247`

verified in code

If a B600 punch is missing, or the exported name does not exactly match (after lowercasing) a known driver name or alias, clock-in is null, no gaps compute, and the day is 'clean' with only an internal dataHealth breadcrumb the dashboard never surfaces. A single spelling drift ('Robert Smith Jr' vs 'Robert Smith') silently zeroes a driver's entire day.

Fix: Emit a distinct 'unknown'/quarantine band for no-punch or no-match days, and add an unmatched-name reconciliation report.

HIGH D8 - Overview and Performance totals do not reconcile

`sentinel-read.js (dist/totalStolen ungated vs dailyPerformance/referenceMetrics/contractorMetrics inside if(meta))`

verified in code

The headline 'unexplained $' and the offenders list count every in-range record, but the Performance daily charts, the reference medians, and the contractor card only count drivers currently on the active roster. Terminate a driver and their historical theft still shows in the headline while vanishing from the Performance trend - the two screens silently measure different populations, with no explanation.

Fix: Include off-roster driver-days (store role/truckType on the record), or clearly label both views 'active roster only'.

MEDIUM D4 - Motive actual drive-time, used as the expected baseline, masks on-route slow-rolling

`_sentinel-scan.js:466-482`

plausible (not runtime-confirmed)

pickLeg uses the actual Motive drive minutes as the 'expected' baseline, so any padding done while moving inside on-route ZIPs is credited as legitimate travel; only stationary loitering stays detectable. The Google typical-traffic figure - the intended 'what it should have taken' - is discarded whenever Motive matched. A 40-min run driven as a 90-min meander reads as on-time.

Fix: Charge max(0, actual - Google typical) for the moving portion, or at least surface both numbers side by side.

MEDIUM D5 - In-route off-route time can double-count with the afternoon gap

`_sentinel-scan.js:353-381,578-581`

plausible (not runtime-confirmed)

An off-route visit is classed in-route by its drive-start time, but its stationary interval can run past the last delivery into the afternoon window - which already charges non-drive time. The overlapping minutes are billed twice (double stolen dollars).

Fix: Clip an in-route visit stationary at last-delivery time (and drive at first-delivery time) so the three windows are strictly disjoint.

MEDIUM D6 - Partial-GPS drives over-attribute stolen minutes

`_sentinel-scan.js:473-482`

plausible (not runtime-confirmed)

The sanity floor only rejects Motive below 25% of Google. Between 25% and the true drive time, an under-measured Motive drive (a coverage gap) understates expected travel and inflates the gap into false stolen minutes - turning a GPS blind spot into an accusation.

Fix: Raise the floor / require Motive to cover a plausible fraction of Google before trusting it; prefer Google when far below.

MEDIUM **D7 - Flat load-prep allowance over-charges long-loading drivers**

`_sentinel-engine.js:158-159,255`

verified in code

The gap subtracts a flat prep constant (15 min default) rather than the Motive-measured pre-drive dwell. A self-loader whose real loading exceeds the config has the excess counted as theft (and pre-loaders are under-charged). Accuracy depends on someone hand-setting each driver correctly.

Fix: Derive prep from measured dwell when Motive is reliable, or flag when the flat allowance and measured dwell diverge sharply.

3. Data wiring & robustness

MEDIUM **W1 - NuVizz by-date overlay query is malformed - dead feature**

`netlify/functions/nuvizz-loads-by-date.js:262-266`

plausible (not runtime-confirmed)

The FETCH overlay calls an event endpoint with an eventDttm filter the documented API does not support and reads response fields that do not match the real shape, so it returns nothing even when deliveries exist. It does not touch scoring, but it is a broken user-facing button.

Fix: Query the documented route/stop-by-date endpoint and read the entityEvents[].events[] fields.

MEDIUM **W2 - Per-date NuVizz raw read truncates at 2000 (single page)**

`_sentinel-scan.js:155-158; sentinel-read.js:277-280`

verified in code

A busy day's fleet-wide raw stops are fetched with a single 2000-row query (no pagination). On a high-volume day this can cut off in name order, so a driver past the cutoff scores with missing completed-stops - under-reported stolen time, with no truncation flag.

Fix: Route through a paginating read with a where-clause, or at minimum surface truncation.

MEDIUM **W3 - Rescore-all has no self-chaining; the UI ignores wall_exhausted**

`sentinel-rescore-all-background.js:242-263`

verified in code

Unlike the historical backfill, the rescore worker just returns 'wall_exhausted' at the 13-minute budget with no successor, and the polling UI only handles complete/error. Once the collection outgrows one budget, a rescore stops half-done, leaving the collection split between two engine versions. Latent today; a time bomb as data grows.

Fix: Auto-chain like the backfill, or re-POST from the UI on wall_exhausted.

MEDIUM **W4 - Dashboard cache keyed on a hand-edited version string**

`index.html cache key vs sentinel-read VERSION`

verified in code

The one-hour dashboard cache keys on APP_VERSION, a string edited by hand in the HTML. A backend payload-shape change without a matching APP_VERSION bump renders old-shape cached data against new code for up to an hour (empty or broken cards).

Fix: Include the backend version in the cache key, or validate the payload shape before rendering from cache.

LOW **W5 - Roster / employee reads still single-page capped**

`sentinel-read.js:161,188,401; nightly/backfill/baselines`

verified in code

Several employee reads use a single 200/500-row query. Fine at ~55 drivers, but silently drops drivers past the cap as the roster grows. The rescore job was already migrated to a paginating read - the pattern is inconsistent.

Fix: Migrate the remaining reads to the paginating helper.

LOW W6 - Performance benchmark reads an external collection single-page at 50000; dead cross-project constant

`sentinel-performance.js:15,114-138`

verified in code

The externally-owned driverPerformanceDaily collection is read with one non-paginating query; large day-ranges truncate silently. A HUB_FIRESTORE_BASE constant points at a different Firestore project and is unused dead code.

Fix: Paginate the read; delete the dead constant.

4. Frontend bugs

MEDIUM F1 - Opening a driver double-fires the loader -> duplicate listener + double fetch

`navigateToDriver / loadInvestigateInit`

verified in code

The first time a user reaches Investigate via any "tap to investigate" path, two concurrent inits run (one from the tab click, one from navigateToDriver). Both attach a change listener, so every later dropdown selection fetches and renders the driver twice for the rest of the session.

Fix: Memoize the init promise, or drop the redundant call in navigateToDriver.

MEDIUM F2 - The trend arrow means the opposite thing in two places

`roster renderTrendIndicator vs report-card KPI deltas`

verified in code

In the roster, ^ (red) means "more theft, worse." On the printable report card, ^ (green) means "better" - so on a coaching document, "Time on route ^ 20m" in green actually means 20m less. Same glyph, opposite meaning, on a page handed to a driver.

Fix: Pick one convention: let the arrow track the value sign everywhere and let color alone carry good/bad, or drop the arrow on the card and use an explicit "faster/less" word.

MEDIUM F3 - Overview does not separate "no data" from "clean" (Audit and Investigate do)

`renderOverviewFromPayload`

verified in code

Audit and Investigate deliberately exclude no-punch / no-delivery days from the clean bucket ("do not paint a feed gap green"). Overview renders the raw distribution and computes "% high-risk" against a total that folds those days in, overstating "clean" and understating risk - contradicting the careful handling everywhere else.

Fix: Return a noData count in the dashboard payload and exclude it from clean; compute the high-risk % against scored days only.

MEDIUM F4 - Settings shows hardcoded thresholds and yard ZIPs as if they were live config

`Settings modal (static HTML)`

verified in code

"Yard ZIP Variants: 30518, 30542" and the static scoring thresholds are literal HTML, never fetched. If the engine values drift, the panel keeps showing the old ones - a manager confirming configuration reads a value that may be false.

Fix: Serve these from the config endpoint, or label them "compiled defaults" so they are not taken as authoritative.

MEDIUM F5 - The "vs typical" column silently changes which metric it means

`renderReferenceDetailBody`

verified in code

The deviation column re-targets whatever column is currently sorted, but the header is a static "vs typical." So the same red "+45%" means morning-gap deviation when sorted one way and stops/hr deviation another - with the active metric never shown. Red reads as "this driver is bad," so the ambiguity is not harmless.

Fix: Put the active metric in the header, or show the deviation per metric.

LOW F6 - "Peer standing" is labeled a median rank but is not one

`openDriverReportCard`

verified in code

medianRank takes the upper-middle rank (for ranks 1..4 it reports 3, not 2.5 - biased worse), and the denominator is the largest peer-group size across metrics, so "3 of 12" can pair a rank computed over 8 drivers with a denominator of 12.

Fix: Compute a true median (rounded) or rename to "typical rank"; use the denominator from the same metric.

LOW F7 - Performance tab has no race guard on range/group clicks

`loadPerformance`

verified in code

Overview uses generation tokens so a slow earlier fetch cannot clobber a newer render; Performance does not. Rapidly tapping 90d then 30d can leave the older (later-resolving) response on screen.

Fix: Apply the same generation-token pattern, or ignore a resolve when the selection changed.

LOW F8 - Report card can print "last undefined days" and mislabel an all-time trend

`openDriverReportCard`

verified in code

If rangeMeta is absent the header/summary render "last undefined days"; and if startDate is missing the trend charts silently plot the driver entire history under a heading still claiming the selected range.

Fix: Guard rangeMeta/startDate; fall back to a neutral label and skip or relabel the charts.

LOW F9 - Dollar tooltip embeds HTML in an SVG title; $/day axis is unlabeled

`rcColChart / rcChartFrame`

verified in code

The $/day chart passes fmt$ (which emits an HTML span) into an SVG <title>, and the y-axis shows bare numbers with no $ sign.

Fix: Use the plain formatter for the tooltip and prefix $ on the axis.

LOW F10 - Reverting a config field to its original value leaves the row stuck "Unsaved"

`wireDriverConfigRow`

verified in code

Typing then deleting back to the original never clears the dirty flag, so the row stays orange and the "Save all (N)" counter stays incremented.

Fix: On input, clear the dirty flag when all fields equal their originals.

LOW F11 - Contractors sort to the extremes on clock-only columns

`CMP_SORTERS`

verified in code

Owner-ops have null clock metrics, mapped to Infinity, so sorting by Clock->1st puts them at the very top as if they had the worst times - though their cell shows a dash.

Fix: Sink nulls to the bottom regardless of direction, or exclude contractors from clock-metric sorts.

LOW F12 - Report-card trend delta can render "$NaN"

`openDriverReportCard`

plausible (not runtime-confirmed)

The delta is gated on current/prior but not on delta itself; a payload with a missing/NaN delta prints "$NaN" while the sentence next to it says "flat."

Fix: Require Number.isFinite(delta) before rendering it.

LOW F13 - Distribution header can show a dangling separator

`renderDistBar`

verified in code

With zero scored days but some no-data days the header renders "0 scored days - - N no data" (empty middle segment between two separators).

Fix: Join the header parts conditionally.

LOW F14 - Report-card peer-median tick may not be the median of the plotted dots

`openDriverReportCard / rcDotStrip`

verified in code

The tick uses the bucket median (a median over driver-days) while the dots are each driver own median - different populations, so the "peer median" line can sit visibly off-center from the dots it summarizes.

Fix: Draw the tick at the median of the plotted per-driver values, or relabel it.

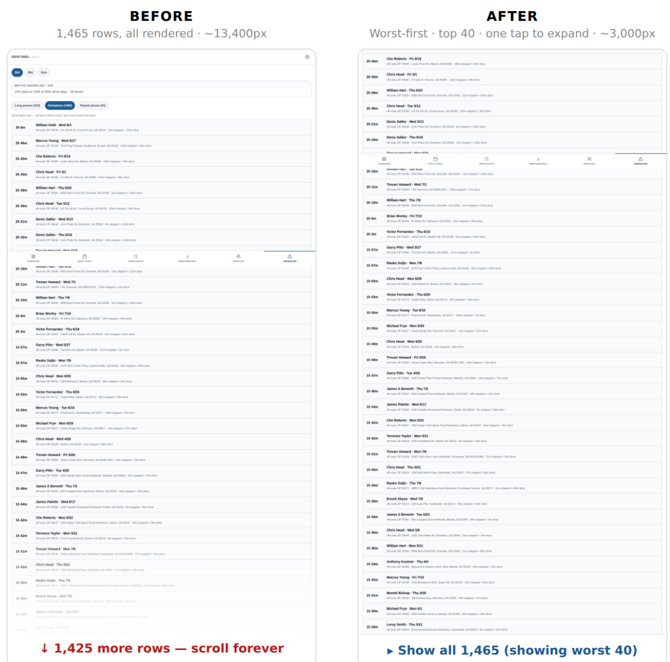
---

5. UI / UX enhancements

The two highest-impact changes are shown before/after below (prototyped, not yet shipped). The remaining items follow as a list.

5a. Anomalies feed - paginate and sort worst-first

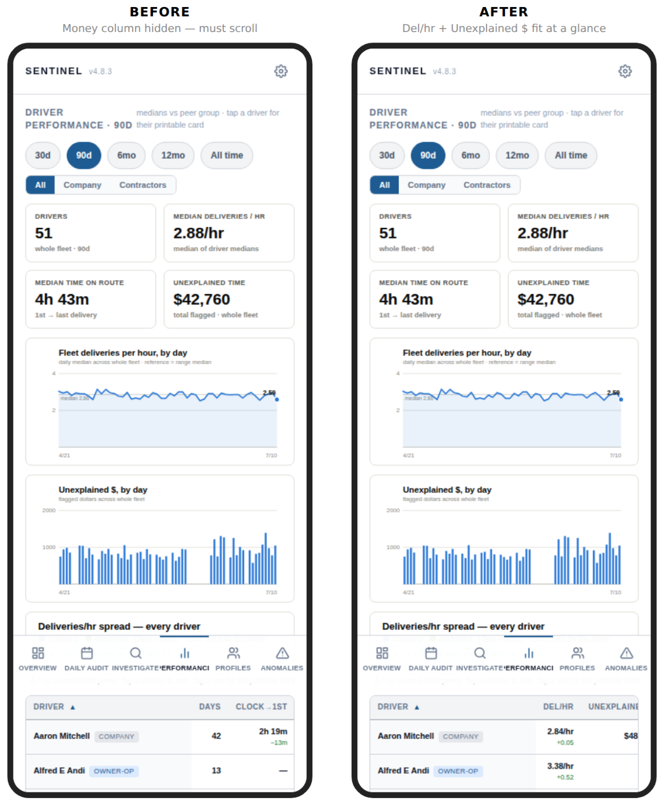
Today the feed renders every row at once (up to ~1,500 rows, ~13,400px tall) in feed order. Proposed: sort worst-first, show the top 40, and add a one-tap "Show all" expander. Same data, instantly scannable, and far lighter on phones.



Anomalies - Deviations view. Before: unbounded scroll wall. After: worst-first top 40 with an expander.

5b. Performance comparison table - make it usable on phones

The 9-column table forces horizontal scrolling on a phone, hiding the Unexplained-$ column - the one a manager most needs. Proposed: on narrow screens collapse to Driver / Deliveries-per-hr / Unexplained $, with the whole row tappable to open the card.



Performance table on a 390px phone. Before: only Days/Clock visible, money column off-screen. After: Del/hr and Unexplained $ fit at a glance.

5c. Additional enhancements

- Anomalies feed (shown below): the list renders every row unbounded (up to ~1,500 rows, ~13,400px). Sort worst-first, cap to the top 40, add a "Show all" expander.
- Performance comparison table on mobile (shown below): the 9-column table needs horizontal scrolling to see anything, hiding the money column. Collapse to Driver / Del-per-hr / Unexplained $ on phones.
- Accessibility: the viewport sets user-scalable=no, which blocks pinch-zoom for low-vision users on a data-dense phone tool. Remove it.
- Accessibility: muted caption text (#94a3b8) is ~2.9:1 on white - below WCAG AA. Bump muted ink to >=4.5:1.
- Accessibility: charts are role="img" with no accessible name, and several encodings are color-only. Add chart titles / aria-labels and non-color cues.
- Modals lack role="dialog", focus trapping, and ESC-to-close; Settings cannot be dismissed by tapping the backdrop. Add a shared dialog behavior.
- Tab labels ("Investigate", "Performance") clip on ~320px phones. Use shorter labels or a scaled layout.
- The "Annualized" figure is a naive x12 extrapolation printed as a hard dollar amount on an app that accuses people of theft. Label it "Projected annual (est.)" and suppress it on sparse windows.
- Only Overview is cached; Profiles and Performance refetch the full 1-3s dashboard on every visit. Share the stale-while-revalidate cache.
- The delivery drill-down brackets rows with CLOCK IN / CLOCK OUT anchors but does not sort them chronologically - sort by delivery time before rendering.

- public/sentinel-nuvizz-patch.js ships in the deploy but is not referenced by index.html - dead asset; remove or wire intentionally.

6. Taking it to the next level

Beyond fixing what is here, these are the moves that would turn SENTINEL from a detection dashboard into a decision system:

- Push, not pull: a daily digest (email/SMS) of new critical driver-days so managers are alerted instead of having to open the app. The infrastructure (Resend/Zapier) is already connected.
- Close the loop to payroll: multiply stolen minutes by each driver actual wage from the payroll/accounting system so "unexplained time" becomes a defensible dollar figure per pay period.
- Exception workflow: let a manager mark a flagged day "explained" (traffic, breakdown, training) with a reason and an audit trail, and suppress it from totals - turning the tool from an accusation engine into a review workflow, and building a labeled set for future tuning.
- Learn habitual legitimate stops: auto-detect recurring benign pauses (a regular lunch spot) and stop re-flagging them, cutting false positives - the anomalies "repeat places" data already half-identifies these.
- Confidence / data-completeness score per day: show how much of the day had B600 + NuVizz + Motive coverage so a manager knows whether a "clean" or a "critical" is trustworthy (directly mitigates the masking bugs D2/D3).
- Repeat-offender escalation: the 30-day trend already exists; add automatic escalation when a driver trends worse for N periods, and a per-driver history sparkline in the roster.
- Lightweight auth + roles before any of this drives discipline: even a single shared login materially reduces the security exposure above and makes the data defensible in an HR context.
- Mobile-first redesign of the comparison table as stacked cards (name + 2-3 key stats + tap for report), rather than a wide scroll table.
- Per-feed freshness banner: show the last ingestion time for B600 / NuVizz / Motive so an all-clean dashboard from a stalled feed is never mistaken for a clean fleet.

Appendix - verified correct

So the report is not read as "everything is broken," these were specifically checked and hold up:

- The dashboard, dates, and anomalies reads correctly use the paginating helper, so the full ~14k-record backfill reaches the aggregates.
- Every dashboard field consumed by the UI is actually produced and persisted by the engine - no wrong-field / wrong-collection reads.
- The backfill epoch-guard chaining is sound against a concurrent reset (masked writes exclude epoch; supersession is checked before every checkpoint).
- The route-match reliability gate (wrong-truck GPS) is applied consistently across travel selection, in-route scoring, rescore, and baselines.
- Scan and rescore produce identical scores for an unchanged record - no drift between the two code paths.
- The "all" contractor+company median is computed as its own median rather than by averaging sub-medians (statistically correct).